ASTRA

Assurance for AI agents and AI models

Keeping AI secure, accountable and under human control, from design to retirement.

ASTRA is a research platform developed at the Institute for Analytics and Data Science (IADS), University of Essex, to support the secure and accountable adoption of artificial intelligence by organisations and public bodies. It operationalises Secure Tropos, an established requirements-engineering methodology for modelling security and accountability, and extends it across the AI life cycle. ASTRA distinguishes two complementary phases of assurance: design-time assurance, in which an AI agent or model is modelled, assessed and formally approved before deployment, and runtime assurance, in which the deployed system is continuously compared with its approved design. Together, these phases provide verifiable evidence of compliance for internal governance, auditors and regulators.

The challenge

The deployment of AI is outpacing the controls that govern it. AI agents increasingly act autonomously, invoke external tools and exchange data with other systems, while the behaviour of AI models changes as their input data evolves or when an externally hosted model is replaced without notice. These developments introduce new cybersecurity and accountability risks. The EU AI Act and data-protection legislation now require organisations to demonstrate, rather than merely assert, that such risks are managed. Assurance performed once, at the point of approval, is therefore insufficient: it must be sustained throughout operation.

From approved design to runtime assurance

Model → Assess → Sign off → Deploy and link → Monitor → Review

- **Design-time modelling.** The organisation first describes its structure: departments, roles, data assets, external services and the regulations that apply to it. Each AI agent or model is then modelled within this context on a visual canvas, either directly or from a natural-language description that a locally hosted assistant drafts and a person corrects. Existing agent definitions and code repositories can also be imported.
- **Design-time assessment.** The design is evaluated against the formal Secure Tropos model, the applicable regulations, the organisation's own policies and, for agents, the OWASP Top 10 risks for agentic AI. ASTRA produces a risk score and a decision (clear, needs review or blocked) and identifies each requirement that is unmet or lacks evidence.
- **Sign-off and contract.** A blocked design cannot be approved. Otherwise, a named compliance reviewer signs off the design, and ASTRA issues it as a versioned, tamper-evident contract: a cryptographically hashed record of what the system is permitted to do, including its tools, data stores, connections, delegations and level of autonomy. Any subsequent change produces a new version, which must itself be approved.
- **Deployment and linkage.** When the system is deployed, the organisation links it to ASTRA through the ASTRA runtime SDK, a lightweight Python library with adapters for the OpenAI Agents SDK and LangChain/LangGraph, or through the OpenTelemetry traces it already produces. Only the type and name of each action are transmitted, never arguments, prompts or personal data, and the SDK never interrupts the running system.
- **Runtime assessment.** Each reported action is compared with the approved contract as it occurs. An action outside the contract, such as an undeclared tool, an unapproved connection or an unexpected delegation, is recorded as a finding, and a new capability opens a drift item. For AI models, ASTRA monitors statistical drift in inputs and outputs, fairness across groups, changes to the underlying model version, indications of sensitive data leaving the organisation, and whether staff genuinely review AI outputs.
- **Review and re-approval.** Each drift item is presented to compliance alongside the approved design. Approval issues a new contract version; rejection is recorded, and the divergence continues to be reported. Where required, the SDK can also refuse a tool call that the contract does not permit before it is executed.

Principal capabilities

- **Visibility of AI in use.** An inventory of the AI systems in the organisation and their accountable owners, including agents that were never registered but are detected at runtime.
- **Consistent, comparable risk measurement.** A single scoring method applied to every system, so that systems and organisations can be compared.
- **Alignment with law and standards.** Designs are mapped to the EU AI Act, GDPR and international frameworks such as NIST and ISO, and gaps are reported explicitly.

- **Accountability.** Named sign-off, separation of duties between those who design, review and deploy, and a complete audit trail.
- **Declared versus observed assurance.** ASTRA reports both the declared risk and the risk observed in operation, together with any contradictions and unevidenced claims. Operational evidence may raise a declared risk but never lower it, and claims must be reconfirmed periodically.
- **Verifiable evidence.** Tamper-evident evidence packs and audit records for regulators and auditors, and concise summaries for external parties that disclose no sensitive detail.

Two modules, one platform

Both modules share the same organisational model, policies and regulations, so that a rule is defined once and applied consistently.

- **AI Agents** addresses autonomous agents that use tools and act independently: inventory and ownership, assessment against agentic threats, ratification, and runtime comparison of each action with the agent's contract.
- **AI Models** addresses models embedded in services and decisions: a pre-deployment compliance score, followed by production monitoring of drift, fairness, model-version changes and human oversight.

Design principles

- **Human authority over decisions.** ASTRA may propose rules extracted from a regulation, but each proposal must quote its source verbatim, and none is enforced until a person has reviewed and approved it.
- **Data minimisation.** The built-in assistant runs on an AI model hosted by the organisation itself, and runtime monitoring retains statistics rather than records, so no personal data is sent to an external AI service.
- **Evidence over assertion.** A critical requirement is regarded as satisfied only when evidence is attached and a named reviewer has signed it off; a claim without evidence is reported as a gap.
- **Organisational ownership of rules.** Organisations can define their own policies, test them on an existing design before adoption, and suspend them without deletion.

Intended users

- **Risk, compliance and data-protection functions,** which require a consolidated view of AI risk and the evidence to demonstrate that it is managed.
- **Teams that develop or procure AI,** which need to identify deficiencies in a design before approval rather than after an incident.
- **Senior leadership and boards,** which are accountable for AI and require a clear and comparable organisation-wide picture.
- **Auditors and regulators,** which require records that can be verified independently.
- **Customers and partners,** which seek assurance about AI without access to sensitive detail.

Questions ASTRA helps to answer

- Which AI systems and agents are in operation, and who is accountable for each?
- Is a system ready for deployment under the EU AI Act and GDPR and, if not, which requirements remain unmet?
- Does the deployed system still behave as its approved design permits, or has it drifted from it?
- Has the model behind an externally hosted service changed since it was approved?
- Is sensitive data leaving the organisation through an AI system?
- Do staff genuinely review AI outputs, or accept them without scrutiny?
- Who approved the system, when, and on what evidence?

Relevance to national AI and cybersecurity

A government can apply the same approach to understand and oversee AI across many public bodies:

- A common, repeatable method to assess AI across ministries, agencies and critical sectors.
- National visibility of where AI is used, the risk it carries and who is accountable for it.
- AI-specific threats, including autonomous agents, data exposure and dependence on externally hosted models, treated as an integral part of cybersecurity.
- An evidence base for procurement, supervision and policy decisions.